PharmaSoft · Lenguaje de Programación II

Guía práctica — Sesión 11

Seguridad frontend: login, sesión, interceptores, guards y permisos

Estudiante: Rodriguez

Fecha de ejecución: 22 de octubre de 2026

> Se ejecutaron los 16 casos contra la SPA local y PharmaBackend conectado a Oracle. Las capturas muestran el resultado visible; los casos de red y almacenamiento se corroboraron inspeccionando las peticiones y sessionStorage, sin incluir el JWT en este informe.

01 · Navegación privada sin sesión



Resultado: al abrir /ventas sin sesión, la SPA redirige a /login y conserva returnUrl=/ventas.

02 · Formulario vacío



Resultado: ambos campos muestran validación local y no se envía una petición de login.

03 · Credenciales incorrectas



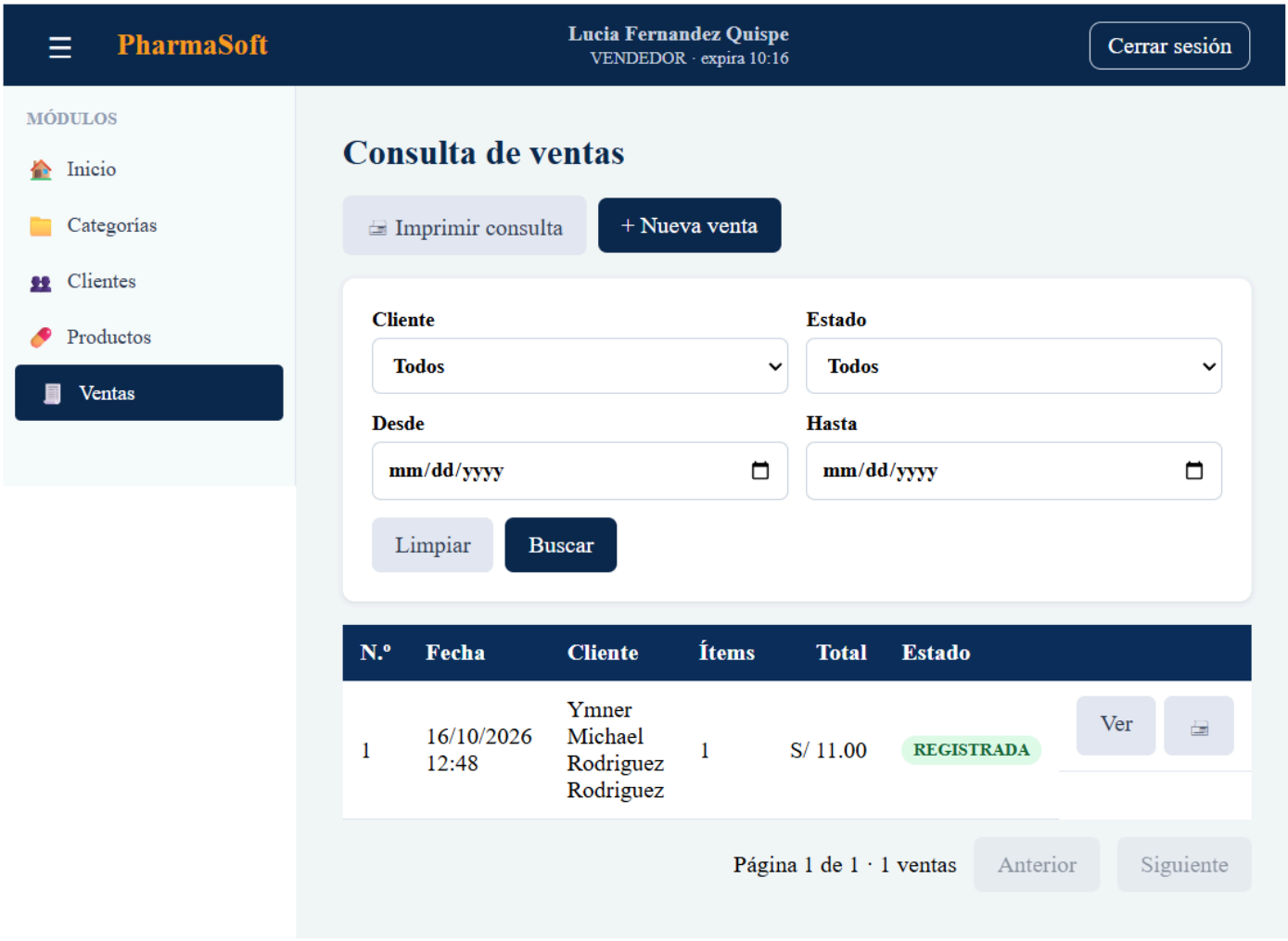
Resultado: se muestra «Usuario o contraseña incorrectos» sin revelar qué dato falló.

04 · Cuenta inactiva



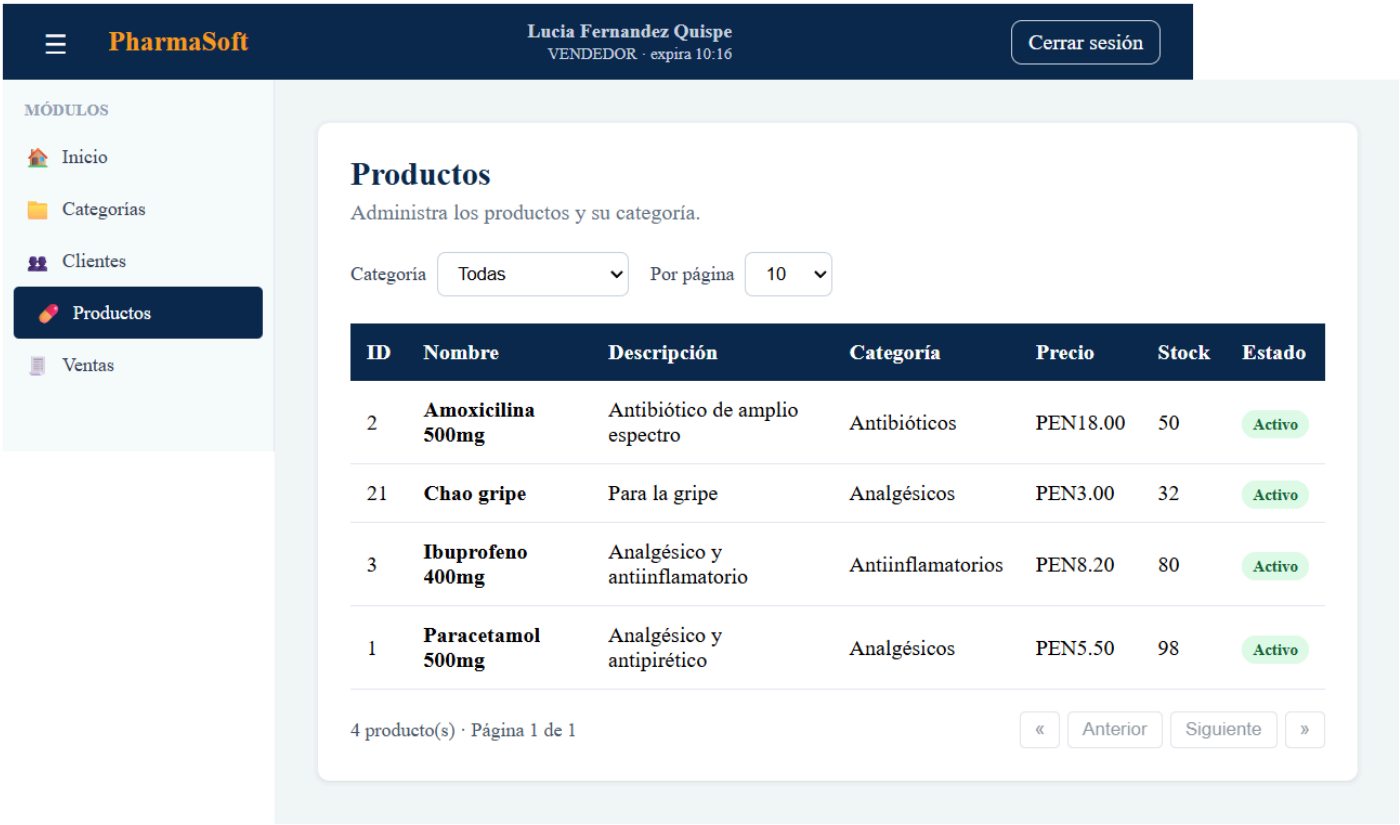
Resultado: el backend responde 401 y la SPA muestra el mismo mensaje genérico; no crea sesión.

05 · Inicio de sesión de vendedor



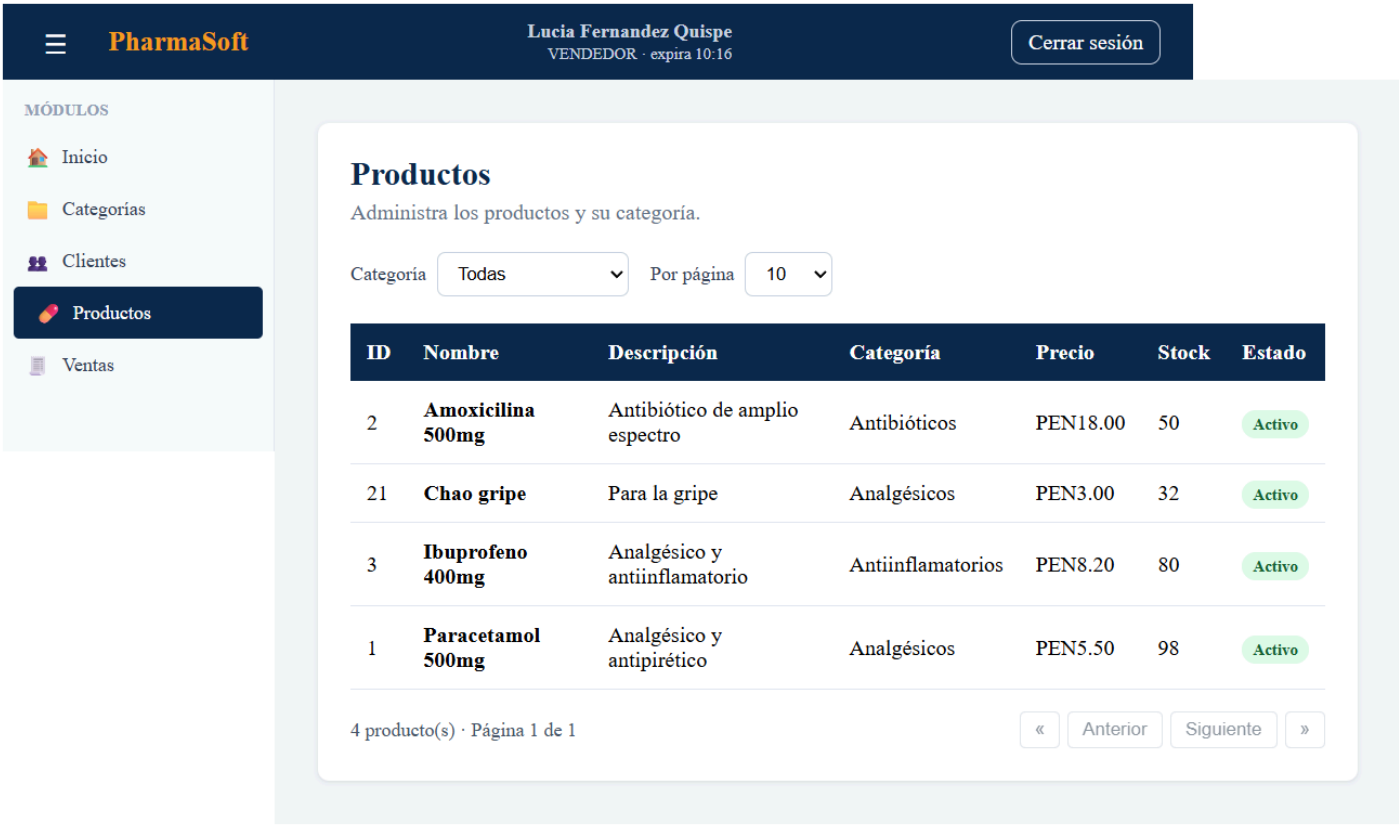
Resultado: vuelve a la ruta solicitada y el encabezado muestra nombre, rol y vencimiento.

06 · Encabezado Authorization



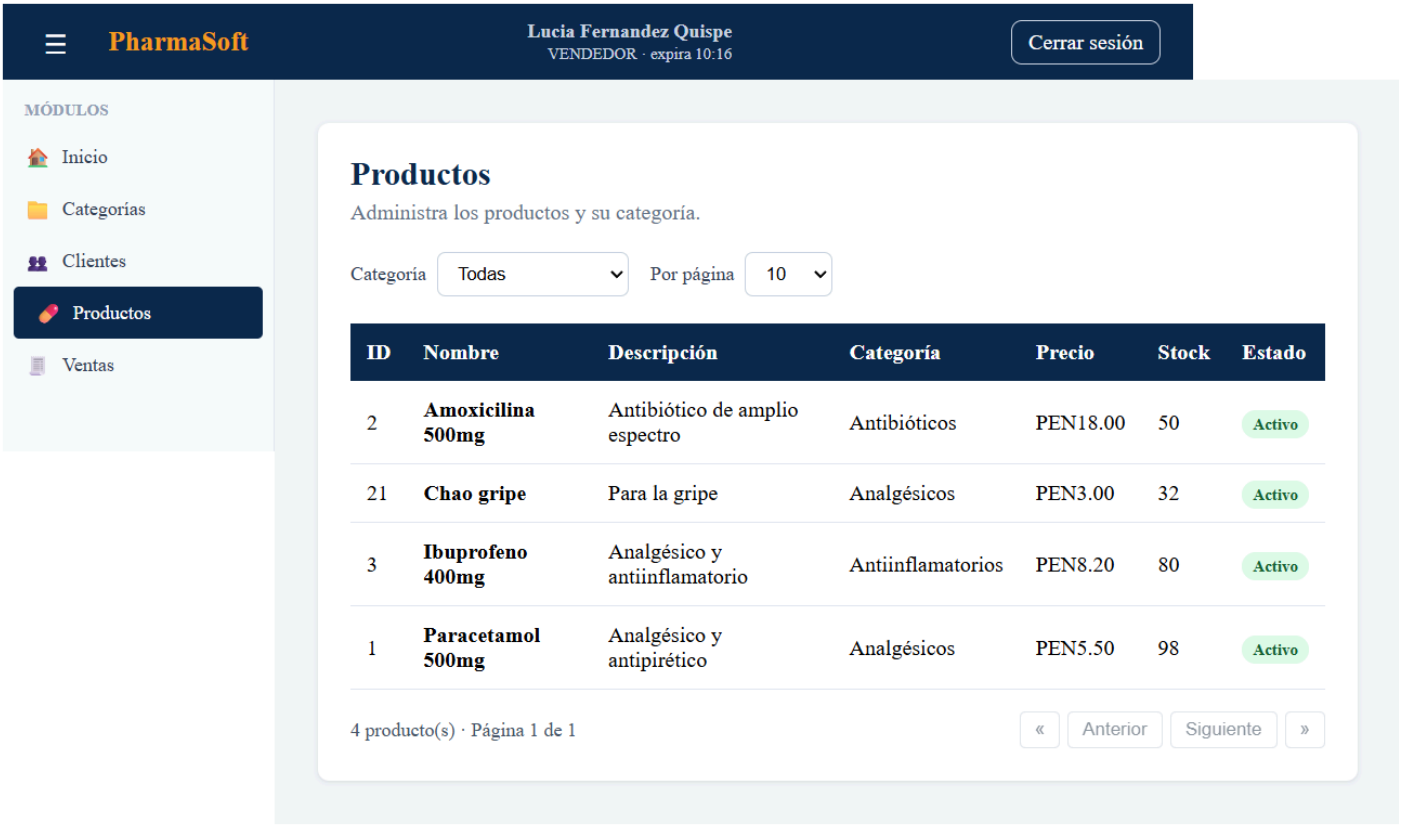
Resultado: POST /auth/login no lleva Authorization; GET /productos lleva Bearer. CORS autoriza http://localhost:4200.

07 · Sesión en sessionStorage



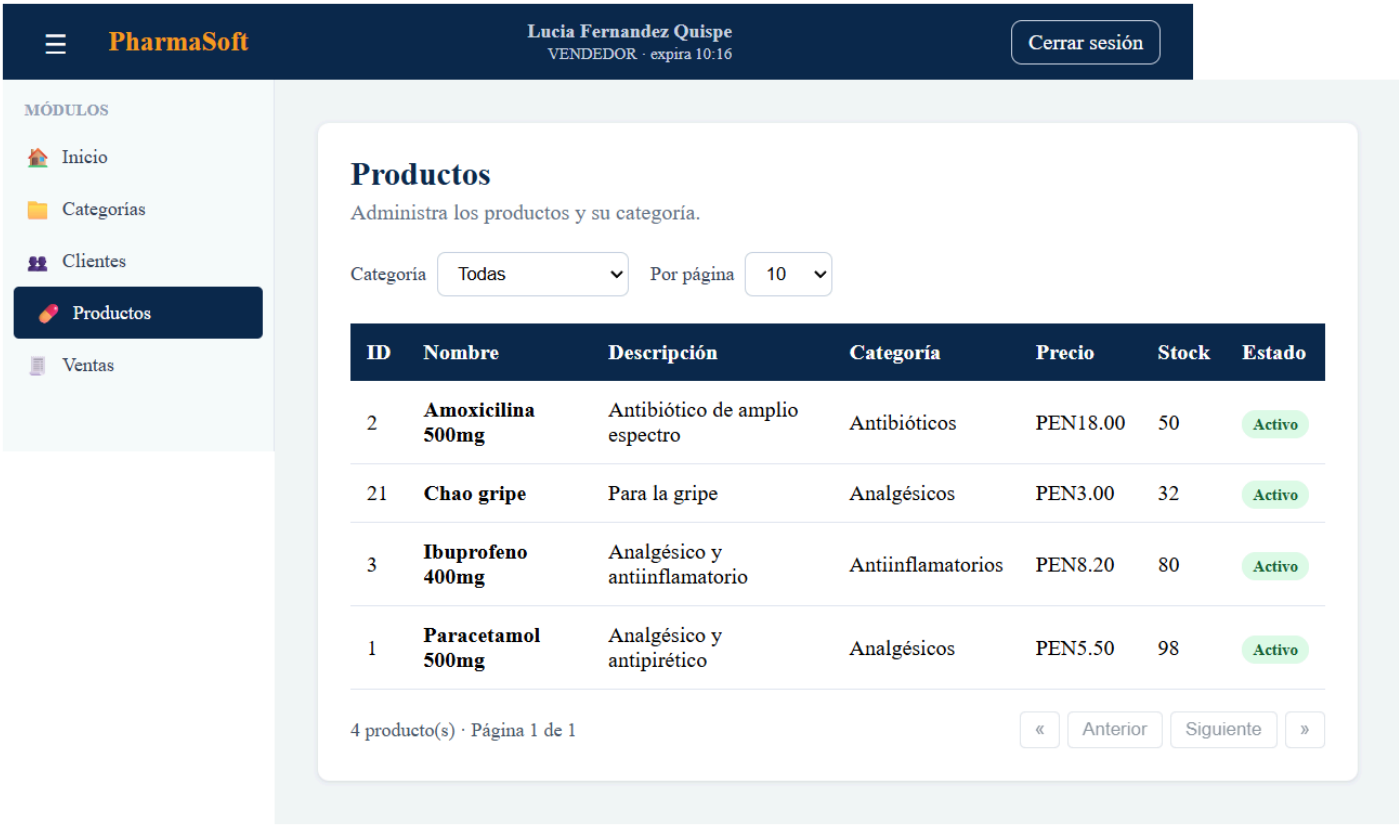
Resultado: existe pharmasoft.sesion con token, expiraEn, username, nombreCompleto, roles y permisos. El token no se imprime en esta evidencia.

08 · Recarga de la página



Resultado: después de F5, se mantiene la sesión y se vuelve a cargar la misma página.

09 · Vendedor con catálogo de solo lectura



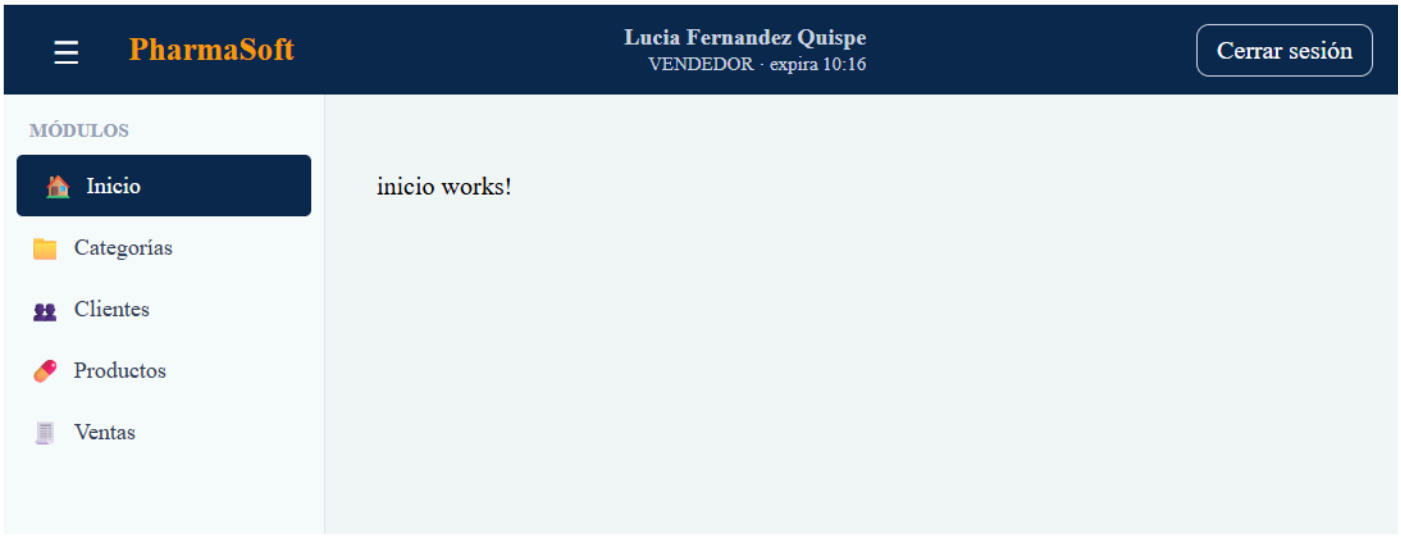
Resultado: no aparecen «Nuevo producto», la columna «Acciones» ni enlaces de edición.

10 · Acceso directo a escritura



Resultado: /productos/nuevo se bloquea con «403 · Acceso denegado» para el vendedor.

11 · Visitante autenticado en /login



Resultado: el guard de invitado redirige al usuario autenticado a /inicio.

12 · Cierre de sesión



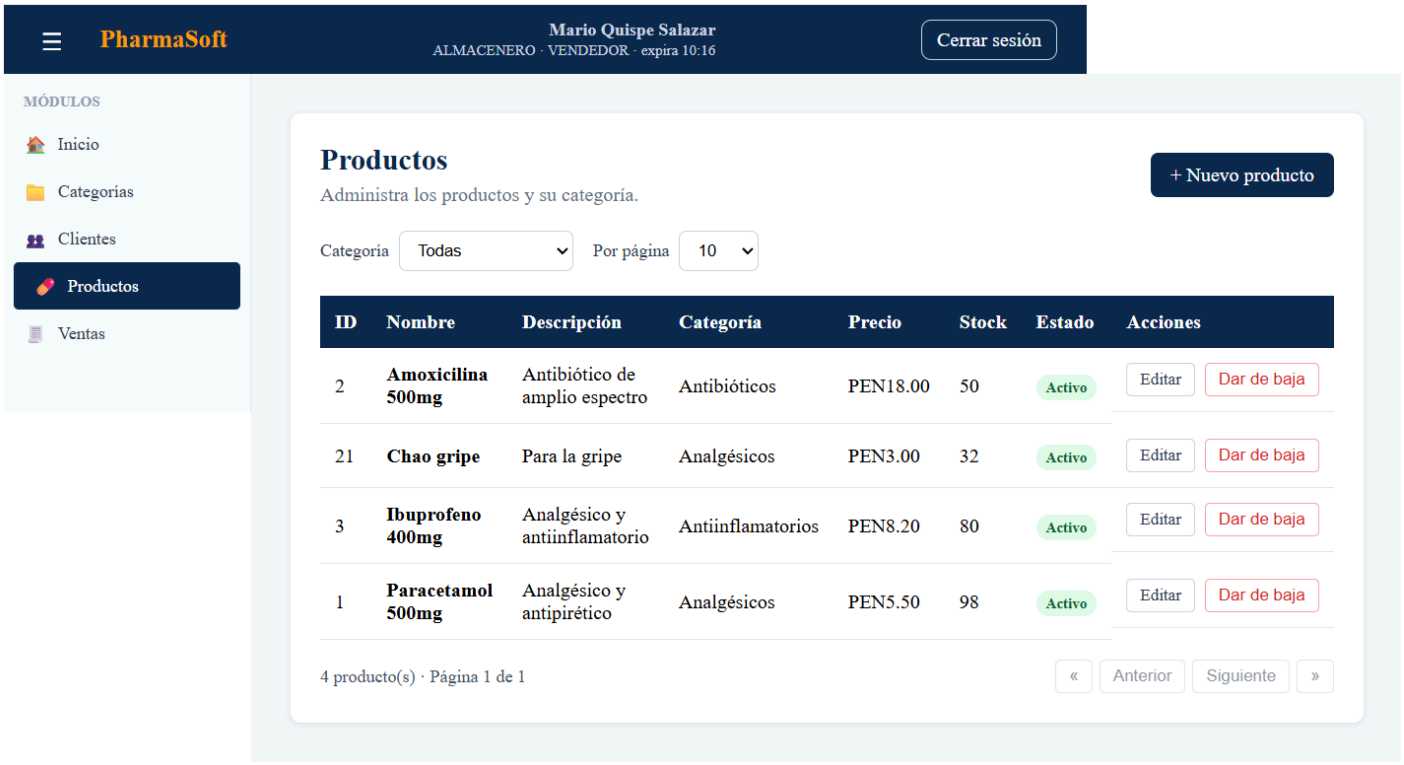
Resultado: vuelve a /login y la clave pharmasoft.sesion deja de existir.

13 · Almacenero sin permiso de ventas



Resultado: Ventas no aparece en el menú y la URL directa termina en acceso denegado.

14 · Supervisor con unión de permisos



Resultado: aparecen Ventas y las acciones de edición del catálogo.

15 · Token alterado



Resultado: el backend devuelve 401; la SPA elimina la sesión y muestra el aviso de expiración.

16 · Vencimiento automático



Resultado: el temporizador cierra la sesión y volver a iniciar sesión conserva la ruta solicitada. Se verificó con una expiración local corta; no se cambió la configuración JWT persistente del backend.